An ninh mạng 1

Một số thuật ngữ về an toàn thông tin

- Thread
  - Hacker, virus, hỏng phần cứng/mềm…
- Vulnerability
  - Thiếu bản vá lỗi bảo mật, password yếu
- Exploit
  - Quá trình khai thác điểm yếu bảo mật
  - Local exploit/remote exploit
- Attack



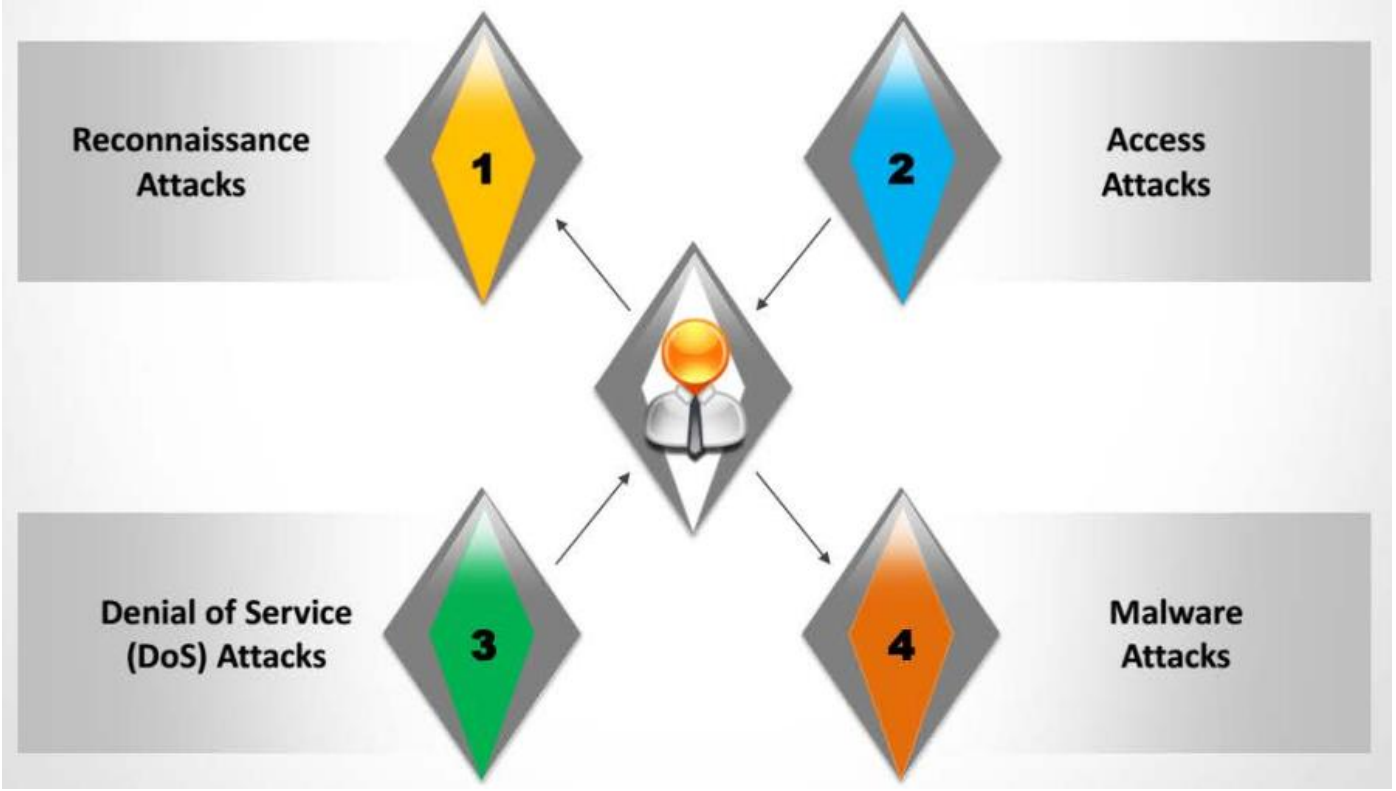
Các kiểu thread

- Internal thread
- External thread
- Unstructured thread
- Structured thread



Một số kiểu tấn công

- Lấy thông tin

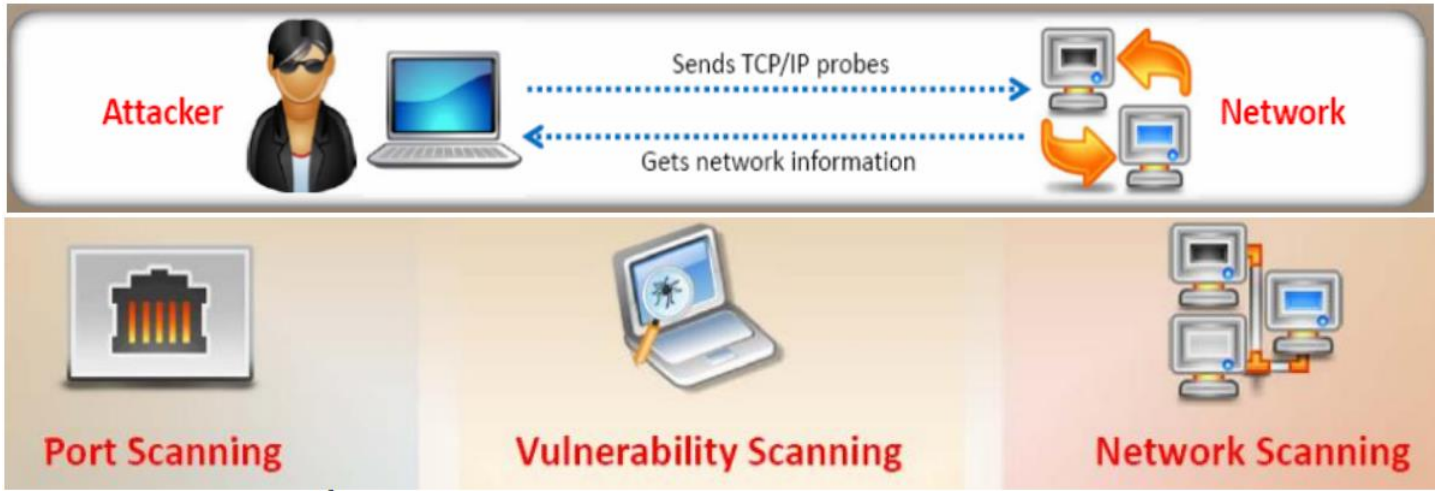


Khai thác điểm yếu Unauthoried access, brute force, privilege escalations, man-in-the-middle

Trojans, virus, worms

Thu thập thông tin

- Mục đích
  - Xác định các host và các port đang hoạt động
  - Các dịch vụ đang chạy trên hệ thống của mục tiêu cần tấn công
- Gửi các gói tin TCP/IP đến mục tiêu
- Phân tích kết quả trả về để lấy các thông tin có giá trị
- Các kiểu scanning
  - Port scanning
  - Vulnerability scanning
  - Network scanning



Thu thập thông tin

- Các kỹ thuật thu thập thông tin
  - Social engineering
  - Port scanning
  - DNS Footprinting
  - Ping Sweeping
- ICMP scanning
- Nmap scan
- https://pentest-tools.com/

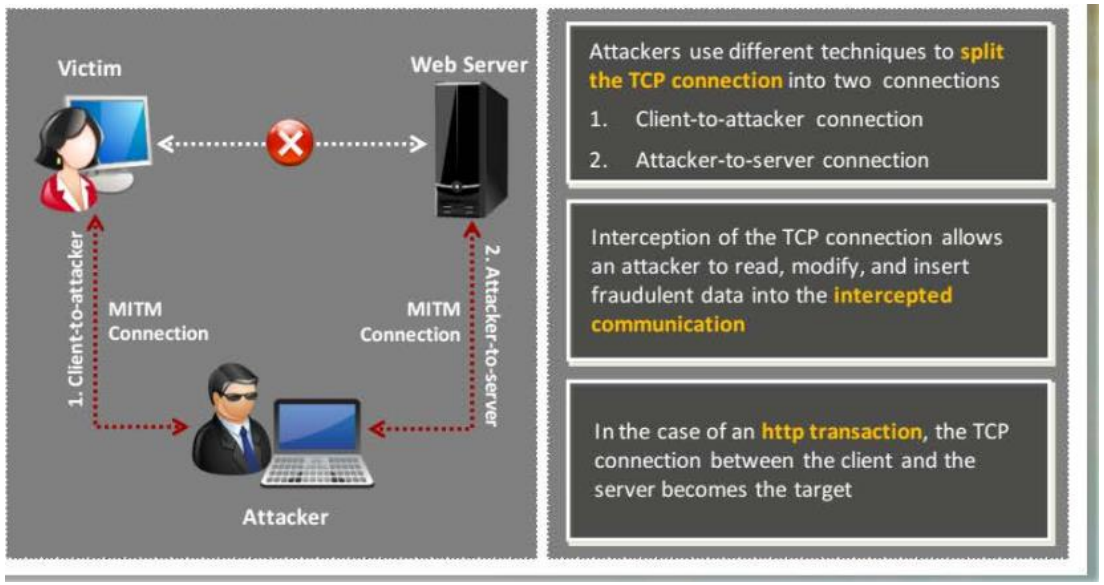


Phòng chống footprinting

- Triển khai firewall
  - Thiết lập chính sách ngăn chặn dò tìm/khởi tạo kết nối không hợp lệ
  - Che dấu cổng mở (chức năng hidden port trong ISA server firewall)
- Tắt các giao thức không dùng trên máy chủ web
- Ngăn ngừa ứng dụng tìm kiếm lưu cache trên web
- Tắt chức năng duyệt thư mục, tách domain nội bộ và domain public
- Thiết kế mạng theo nguyên tắc phòng thủ theo chiều sâu
  - Có firewall và IDS phát hiện bị quét cổng

Access attack

- Password attack
  - Tấn công server và router
  - Kỹ thuật brute-force, social engineering, spoofing, phishing, malware, sniffing
- Network sniffing
  - Bắt gói tin
- Man-in-the-middle attack



Access attack

- Replay attack



Access attack

- Privilege escalation
  - Sử dụng tài khoản mức thấp để lấy quyền admin
- DNS poisoning
- DNS cache poinsoning
- ARP poinsoning
- DHCP starvarion attack
- DHCP spoofing attack
- Switch port stealing
- MAC spoofing/duplicating

Access attack

- Bẻ khóa mật khẩu
  - Passive online: nghe trộm sự thay đổi mật khẩu trên mạng
    - Sniffing, man-in-the-middle-attack, replay attack (tấn công dựa vào phản hồi)
    - Đánh hơi (sniffing) tìm dấu vết mật khẩu trên mạng
    - Capture trong quá trình xác thực → so sánh với từ điển hoặc danh sách từ
    - Mật khẩu thường được băm hoặc mã hóa trước khi gửi lên mạng → bẻ khóa
  - Active online: đoán trước mật khẩu người quản trị (áp dụng cho mật khẩu yếu)
    - Công cụ tạo ra từ điển, danh sách từ… để đoán mật khẩu

Access attack

- Bẻ khóa mật khẩu
  - Offline: dictionary, hybrid, brute-force
    - Yêu cầu phần cứng để truy cập vật lý vào máy tính để sao chép các tập tin mật khẩu

Type of Attack	Characteristics	Example Password
Dictionary attack	Nỗ lực để sử dụng mật khẩu từ từ điển	Administrator
Hybrid attack	Thay thế một vài ký tự của mật khẩu	Adm1n1strator
Brute-force-attack	Thay đổi toàn bộ ký tự của mật khẩu	Ms!tr245@F5a

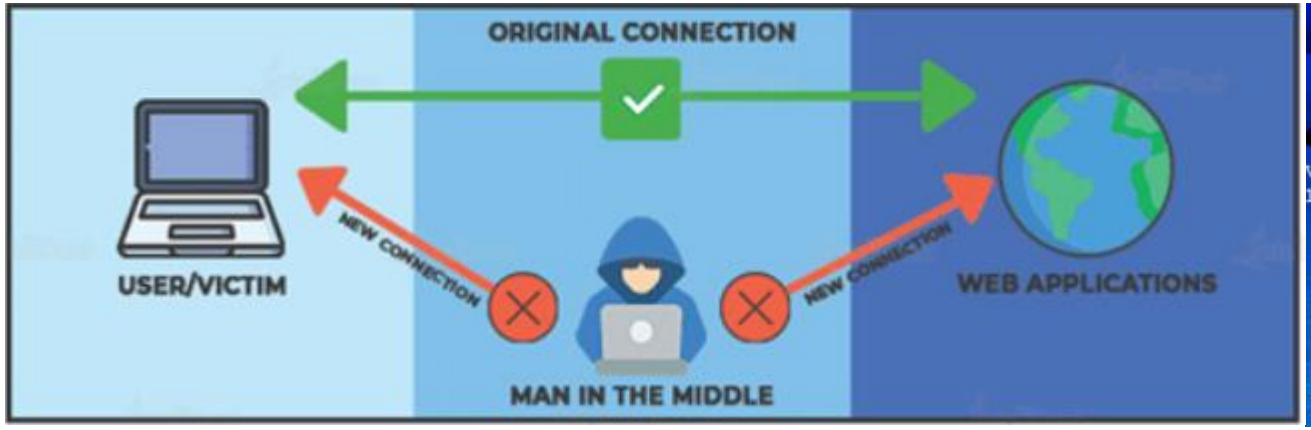
  - Non-electronic: social engineering, phising

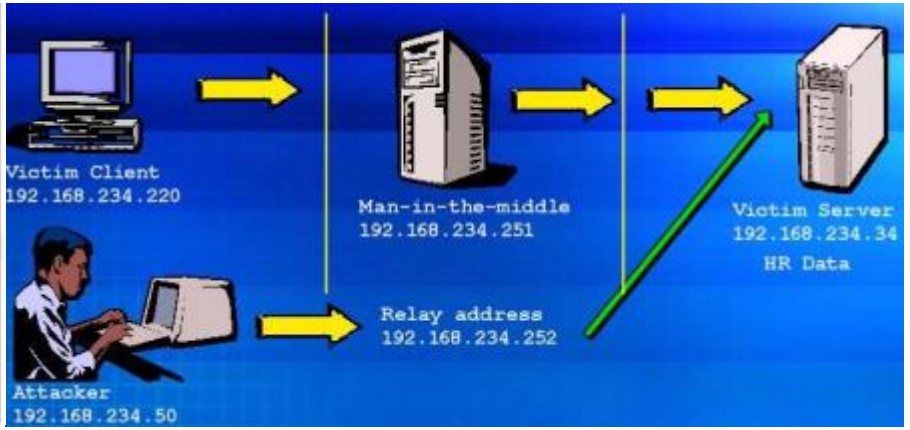
Access attack

- Bẻ khóa mật khẩu
  - Một số công cụ
  - Legion: quét nhiều máy tính cùng một lúc thông qua IP để tìm tài nguyên chia xẻ và đoán mật khẩu tự động
  - NTInfoscan/CIS
    - Truy cập TCP/UDP qua các cổng 135-139
    - Vô hiệu hóa binding tới các máy client trên bất cứ card mạng nào
  - Lophtcrack/LC5/LC6
  - KerbCrack
    - Kerbsniff: capture gói tin
    - Kerbcrack: crack

Access attack

- Man-in-the-middle attack
  - Victim client kết nối đến server giả tạo tại địa chỉ 192.168.234.251
  - MIMT chặn kết nối, giải mã password và chuyển kết nối đến máy chủ thật sự
  - Thực hiện: gửi link đến victim





Access attack

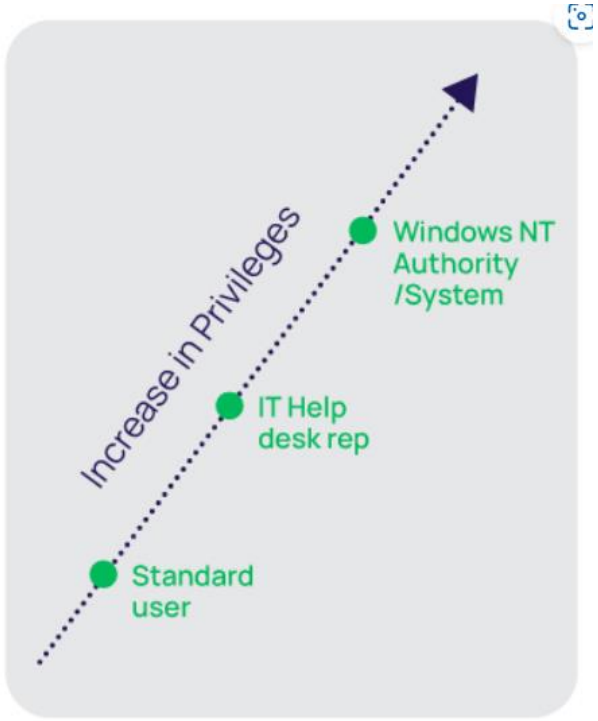
- Man-in-the-middle attack
- Công cụ
  - SMB Grind
  - SMBDie
  - PacketCreator
  - Ettercap,
  - dSniff,
  - MITMPROXY,
  - Bettercap,
  - and Cain and Abel

Access attack

- Privilege escalation (leo thang đặc quyền)
  - Khai thác lỗi (thiết kế/HĐH/ứng dụng) để có quyền truy cập cao hơn



Horizontal Privilege Escalation Attack



Vertical Privilege Escalation Attack

Access attack

- Privilege escalation
  - Sử dụng tài khoản mức thấp để lấy quyền admin
  - Xác định các mức đặc quyền trong windows
    - Systeminfo: overview OS
    - Wmic qfe: xem các bản update của OS, tận dụng các lỗ hổng chưa update
    - wmic useraccount get name,sid.
    - Whoami: vai trò hiện tại (whoami /priv, /group)
    - Net user: hiển thị các users (net user username)
    - Net localgroup: hiển thị các group (net local group Administrator)
  - Tool: WinPEAS (Windows Privilege Escalation Awesome Scripts)
    - PowerUp, Seatbelt

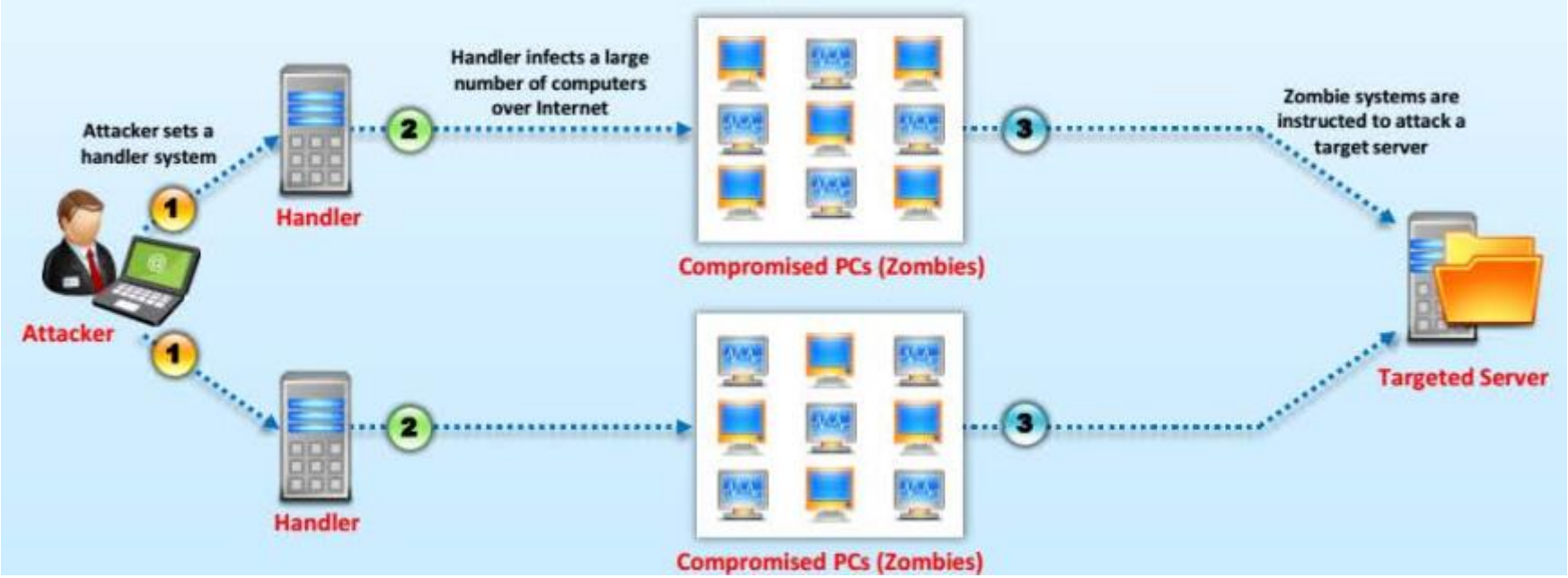
Access attack

- Privilege escalation
  - Một số lệnh enumeration

Enumeration Commands	Description
ver	Windows Version
whoami	Current user
hostname	System Hostname
systeminfo	System Information
sc query state=all	Display Services
tasklist /svc	Display processes and services
ipconfig	Show IP Configuration
net users	Show Local Users
net localgroup	Show Local Groups
netsh advfirewall show allprofiles	Display Firewall Profiles and State

Deny of service – DoS/DDoS

- DoS ngăn chặn người dùng truy cập mạng bằng cách tấn công network bandwidth
- DDoS



Malware attack

- Virus
- Trojan
- Adware
- Spyware
- Rootkit
- Backdoor